DIRECTIVE SUR L'UTILISATION ACCEPTABLE DES TECHNOLOGIES DE L'INFORMATION

Avis de confidentialité

Ce document contient des informations qui sont destinées à l'usage exclusif de iA Groupe financier.

Sous réserve d'une approbation d'un représentant dûment autorisé de iA Groupe financier, toute reproduction de ce document, ou sa distribution à l'extérieur de son groupe autorisé d'utilisateurs est interdite.

Table des matières

1. Introduction 3
   1.1. Portée 3
   1.2. Contexte 3
   1.3. Définitions 3
2. Exigences de cette directive 4
   2.1. Respect des contrôles de sécurité en vigueur 4
   2.2. Gestion des identités et des accès 4
   2.3. Usage éthique et professionnel 5
   2.4. Usage personnel occasionnel et raisonnable 6
   2.5. Équipements informatiques fournis par l'entreprise 7
   2.6. Équipements informatiques personnels et de tiers 7
   2.7. Outils de collaboration 8
3. Écarts et exceptions 8
4. Signalement des incidents de sécurité de l'information 8
5. Surveillance et enquêtes sur les activités 9
6. Sanctions applicables 9

Directive sur l'utilisation acceptable des technologies de l'information	
Propriétaire	Chef de la sécurité de l'information (CISO)
Portée	Groupe
Objectif de la Directive	Établir et communiquer les responsabilités des employés et de toute personne ou entité participant aux activités de la Société en ce qui concerne l'utilisation des technologies de l'information (TI), ainsi que les actions nécessaires ou à éviter afin d'assumer ces responsabilités.
Date de révision	s.o.
Autorité d'approbation	Comité directeur sur la sécurité de l'information (CDSI)
Date d'approbation	7 avril 2022
Date d'entrée en vigueur	7 avril 2022
Fréquence de révision	Aux trois (3) ans ou à la suite de changements majeurs
Prochaine révision	2025-04

1. Introduction

1.1. Portée

La *Directive sur l'utilisation acceptable des technologies de l'information* s'applique à iA Groupe financier, à ses employés, à ses fournisseurs de services et à ses sous-traitants, consultants et toute personne dont le travail est sous la responsabilité de la direction de la Société, sur laquelle la Société exerce un contrôle direct et qui utilise les actifs de iA Groupe financier.

1.2. Contexte

Les organisations mettent à la disposition de leurs utilisateurs des informations et des technologies de l'information pour soutenir leurs activités. Afin de favoriser une utilisation sécuritaire et éthique, et de rencontrer leurs différentes obligations, elles doivent établir et communiquer les exigences applicables et spécifier les comportements à adopter.

1.3. Définitions

Une « *homologation par la VPTI* » désigne la validation, notamment du point de vue de la sécurité de l'information, et l'approbation de l'utilisation d'une technologie de l'information par la Vice-Présidence, Technologies de l'information (VPTI).

Les « *informations de l'entreprise* » sont celles qui sont détenues par la Société ou par un tiers pour le compte de la Société, y compris, sans s'y limiter, les informations relatives à ses finances, à ses employés, à ses clients, à ses fournisseurs et à la Société.

« *iA Groupe financier* » ou « *la Société* » désigne iA Société financière inc. et ses filiales directes et indirectes, exerçant leurs activités sous le nom iA Groupe financier.

Un « *incident de sécurité de l'information* » est un événement ou une série d'événements indésirables ou inattendus qui ont une probabilité importante de compromettre les activités de la Société et de menacer la sécurité de l'information. La perte ou le vol d'un ordinateur portable, la transmission d'informations confidentielles par courriel au mauvais destinataire et les tentatives d'hameçonnage sont des exemples d'incidents de sécurité de l'information.

Une « *information confidentielle* » désigne l'information qui ne doit être communiquée ou rendue accessible qu'aux personnes et aux entités autorisées. On parlera plus spécifiquement « d'information critique » lorsqu'une information confidentielle a le potentiel de mettre en péril l'intégrité de la personne ou de l'organisation qu'elle concerne.

Un « *renseignement personnel* » désigne toute information qui concerne un individu et qui peut permettre de l'identifier soit directement, c'est-à-dire par la simple consultation de cette seule information, soit indirectement, c'est-à-dire par recoupement avec d'autres informations, et ce, quel que soit le support ou la forme sous laquelle ce renseignement est accessible.

Un « *utilisateur* » désigne toute personne faisant usage de l'information et des technologies de l'information de l'entreprise incluant, mais sans s'y limiter, les employés, les consultants et les conseillers des réseaux de distribution.

2. Exigences de cette directive

2.1. Respect des contrôles de sécurité en vigueur

Des contrôles de sécurité de nature administrative, physique et technologique sont mis en place afin de sécuriser les informations et les technologies de l'information de l'entreprise.

Dans cette optique, les utilisateurs doivent respecter les exigences suivantes :

a. Ne pas chercher à désactiver ou contourner d'une autre façon les contrôles de sécurité de la Société ou inciter d'autres personnes à le faire (p. ex. : en transmettant des informations à une personne ne disposant pas de cet accès, en laissant entrer une personne n'ayant pas de carte d'accès dans les bureaux de la Société).
b. Traiter les informations de l'entreprise uniquement par l'entremise de services homologués par la VPTI et pour l'usage pour lequel ils ont été prévus.
c. Ne pas publier sur des sites Web publics ou sur les réseaux sociaux des informations qui contiennent des informations confidentielles ou qui peuvent porter atteinte à la sécurité de l'information et des technologies de l'information de l'entreprise.
d. Suivre les parcours obligatoires de formation et de sensibilisation à la sécurité de l'information afin de comprendre les comportements responsables attendus en la matière.

2.2. Gestion des identités et des accès

L'utilisation de mots de passe et d'autres données d'authentification (p. ex., les NIP, les jetons d'authentification, les données biométriques, les cartes d'accès, les questions et réponses secrètes) est l'un des principaux moyens permettant de protéger l'accès aux informations et aux technologies de l'information de la Société. À ce titre, les utilisateurs doivent préserver leur confidentialité, car ils demeurent responsables des activités résultant de l'utilisation de leurs comptes.

Dans cette optique, les utilisateurs doivent respecter les exigences suivantes :

a. Fournir des informations valides et complètes reliées à leur identité lorsqu'elles sont demandées et les faire corriger si elles sont inexactes.
b. Se soumettre aux étapes de vérification de l'identité lorsque nécessaire (p. ex., lors de l'émission de leur compte utilisateur, de la réinitialisation de leur mot de passe ou du remplacement d'un appareil mobile).
c. S'identifier et s'authentifier, lorsque cela est demandé, pour accéder à l'information et aux technologies de l'information qu'ils sont autorisés à utiliser.
d. Choisir des mots de passe qui respectent les règles de composition établies par la Société.
e. Ne pas utiliser les mêmes mots de passe pour différents comptes utilisateurs.
f. Choisir des questions et réponses secrètes qui sont difficiles à deviner pour autrui afin de prouver leur identité en cas d'oubli de leur mot de passe.
g. Garder secrètes ses données d'authentification en :

    - ne les partageant pas;
    - les protégeant contre le vol et les indiscrétions;
    - ne les stockant pas sur un papier, dans un document numérique ou sur tout autre support qui pourrait être compromis.

h. Accéder uniquement aux informations et aux technologies de l'information nécessaires à l'exercice de leurs fonctions et ne pas tenter de dépasser le niveau d'accès autorisé.
i. Ne pas utiliser le compte utilisateur ou le mot de passe d'un autre utilisateur.
j. Changer immédiatement leur mot de passe et signaler un incident de sécurité de l'information lorsqu'ils soupçonnent que leur mot de passe a été compromis ou lorsqu'exigé.

2.3. Usage éthique et professionnel

Les utilisateurs disposent d'accès privilégiés à l'information et aux technologies de l'information de l'entreprise, ce qui implique qu'ils doivent les utiliser adéquatement afin de prévenir tout accès, divulgation, altération ou destruction non autorisés. Leur utilisation doit être conforme aux politiques corporatives, au code de conduite professionnelle, de même qu'aux lois et à la réglementation qui régissent les activités de la Société.

Dans cette optique, les utilisateurs doivent respecter les exigences suivantes :

a. Adopter des comportements éthiques et professionnels en s'abstenant d'utiliser les informations et les technologies de l'information de l'entreprise :

    - Pour des activités commerciales autres que celles qui sont incluses dans leurs fonctions;
    - Pour créer, consulter, stocker ou envoyer du contenu illégal ou offensant, notamment du contenu sexuellement explicite, raciste ou discriminatoire, ou encore tout contenu considéré comme inapproprié par la Société;
    - Pour envoyer de messages non sollicités, de la publicité, ou des chaînes de lettres à des personnes qui n'ont pas expressément demandé à recevoir ce type de contenu;
    - Pour toute autre fin susceptible de causer du tort à la Société, à ses clients ou à ses fournisseurs.

b. Ne pas partager des informations de l'entreprise avec d'autres utilisateurs qui ne sont pas autorisés ou avec des membres de leur domicile.
c. Ne pas partager des informations de l'entreprise avec des tiers, sauf si cela a été préalablement autorisé et qu'une entente de confidentialité permette de garantir que le tiers les protégera de manière adéquate.
d. Obtenir une autorisation avant de modifier, détruire, déplacer, chiffrer, déchiffrer ou divulguer, en tout ou en partie, une information confidentielle.
e. Ranger sécuritairement les documents papier ou les supports de stockage amovibles contenant des informations confidentielles lorsqu'ils ne sont pas utilisés ou qu'ils sont laissés sans surveillance.
f. Fermer ou verrouiller les sessions d'activité lorsque les équipements informatiques sont laissés sans surveillance.
g. S'abstenir d'imprimer, de photocopier ou de télécopier des documents contenant des informations confidentielles, sauf si c'est prévu dans leurs fonctions. Le cas échéant, les documents doivent être retirés immédiatement.
h. Faire attention lorsqu'ils partagent leur écran pour ne pas divulguer des informations de l'entreprise à des personnes non autorisées.
i. Faire preuve de discrétion lors de déplacements, dans des lieux publics ou dans un environnement où des personnes non autorisées sont présentes, incluant :

    - Éviter de discuter des affaires de la Société en présence de personnes non autorisées;
    - Protéger contre la visualisation du clavier ou des informations affichées sur leur écran.

j. Ne pas conserver les informations de l'entreprise, incluant les copies, après la fin d'emploi ou de contrat.
k. Détruire, de manière sécurisée (p. ex., par déchiquetage), les documents papier qui contiennent de l'information confidentielle lorsqu'ils ne sont plus nécessaires.
l. Ne pas conserver les documents numériques qui contiennent de l'information confidentielle lorsque l'information n'est plus nécessaire.

2.4. Usage personnel occasionnel et raisonnable

Toute utilisation des équipements informatiques de l'entreprise, y compris à des fins personnelles, peut faire l'objet d'une surveillance. La Société tolère un usage occasionnel et raisonnable des technologies de l'information à des fins personnelles sous certaines conditions.

Dans cette optique, les utilisateurs doivent respecter les exigences suivantes :

a. Limiter leur utilisation des équipements informatiques de l'entreprise à des fins personnelles afin de respecter les conditions suivantes :

    - L'utilisation s'effectue en dehors des heures de travail, soit pendant les pauses ou les repas.
    - L'utilisation ne les empêche pas de remplir toutes leurs obligations professionnelles et de fournir une prestation de travail pleine et entière.
    - L'utilisation n'implique pas de technologies de l'information non-homologuées par la VPTI.

- L'utilisation ne contrevient pas aux exigences de la présente directive ou d'autres exigences de sécurité.

2.5. Équipements informatiques fournis par l'entreprise

iA Groupe financier fournit à la plupart de ses utilisateurs des équipements informatiques afin d'accomplir leur travail. Ces équipements comprennent des ordinateurs de table et portables, des appareils mobiles, des équipements de télécommunications ainsi que d'autres dispositifs et périphériques.

Dans cette optique, les utilisateurs doivent respecter les exigences suivantes :

a. Protéger les équipements informatiques de l'entreprise contre le vol, la perte et l'endommagement.
b. Collaborer à l'application des mises à jour de sécurité, lorsqu'ils sont invités à le faire par la VPTI.
c. Ne pas partager les équipements informatiques de l'entreprise avec des membres de leur domicile ou des tiers non autorisés.
d. Utiliser uniquement les services d'entretien et de réparation d'équipement informatique de la Société.
e. Obtenir une autorisation explicite avant de sortir un équipement informatique des bureaux de l'entreprise.
f. Utiliser des dispositifs homologués par la VPTI et dotés de capacités de chiffrement, si des dispositifs de stockage amovibles (p. ex., une clé USB) sont nécessaires.
g. Utiliser ou installer uniquement des logiciels homologués par la VPTI à partir de sources d'installation officielles (p. ex., le portail d'entreprise).
h. Remettre les équipements informatiques avant toute fin d'emploi ou de contrat.
i. Se conformer aux procédures de la VPTI lorsque les équipements informatiques doivent être éliminés, réutilisés, ou transmis hors du contrôle de la Société (p. ex., lors de la vente d'équipements informatiques aux employés, lors de l'entretien et la réparation).
j. Ne pas installer, déplacer, ou désinstaller sans autorisation un équipement de télécommunication (p. ex., routeur, modem, téléphone) sur le réseau de l'entreprise.
k. Éviter les activités pouvant provoquer une congestion ou une perturbation du réseau informatique et des infrastructures de l'entreprise, par exemple en utilisant la bande passante de manière excessive.
l. Se connecter par l'intermédiaire d'une connexion homologuée par la VPTI (p. ex., un réseau privé virtuel (RPV ou VPN)) lors de l'utilisation de réseaux publics pour accéder aux informations de l'entreprise.

2.6. Équipements informatiques personnels et de tiers

Sous certaines conditions, des équipements informatiques personnels ou de tiers peuvent accéder aux informations ou aux technologies de l'information de l'entreprise. Des expériences mobiles minimales et enrichies sont disponibles respectivement pour les appareils non inscrits et les appareils inscrits.

Dans cette optique, les utilisateurs doivent respecter les exigences suivantes :

a. S'assurer que l'utilisation des équipements informatiques personnels ou de tiers ne contrevient pas aux exigences de la présente directive.

b. Détruire de manière sécurisée (p. ex., par désinscription de l'appareil) les informations de l'entreprise stockées sur des équipements informatiques lorsque ceux-ci ne sont plus utilisés pour le compte de la Société ou transmis hors du contrôle de la Société.
c. Ne pas connecter des équipements qui n'ont pas été homologués par la VPTI au réseau de l'entreprise, à l'exception du réseau sans-fil mis à la disposition des invités.

2.7. Outils de collaboration

Les outils de collaboration mis à la disposition des utilisateurs pour la conduite des affaires incluent notamment les services de courrier électronique, de messagerie instantanée, de visioconférence, de téléphonie, de bureautique et de stockage en ligne. Ces outils sont couramment utilisés comme vecteurs d'attaque par des individus et des entités malveillants (par exemple, attaque d'hameçonnage). Ils peuvent également être utilisés de manière inadéquate lors du traitement d'informations confidentielles, car ils ne sont pas nécessairement conçus à ces fins.

Dans cette optique, les utilisateurs doivent respecter les exigences suivantes :

a. Utiliser uniquement les outils de collaboration homologués par la VPTI, y compris leur adresse de courrier électronique d'entreprise, pour les communications liées aux activités de iA Groupe financier.
b. Transmettre des informations de l'entreprise uniquement à des destinataires autorisés à recevoir ces informations.
c. Ne pas rediriger le contenu de ces outils vers des outils personnels, que ce soit en utilisant une fonction de transfert automatique ou de manière ponctuelle.
d. Ne pas transmettre d'informations confidentielles à l'interne ou à l'externe sans appliquer les mesures de protection appropriées (p. ex., chiffrement de fichier, envoi d'un lien vers un dépôt de fichier sécurisé).
e. Être vigilants dans leur utilisation de grandes listes de distribution et d'envois massifs.
f. S'identifier clairement et ne pas agir de façon anonyme.
g. S'abstenir d'ouvrir les messages et les pièces jointes suspects et signaler les tentatives d'hameçonnage.

3. Écarts et exceptions

Dans les cas où cette directive n'est pas respectée, une demande de dérogation doit être remplie en suivant le processus de dérogation au cadre normatif de sécurité de l'information.

Veuillez contacter l'équipe de sécurité de l'information < DemandesSecuriteSI@ia.ca > pour obtenir plus d'informations sur ce processus ou sur la directive, le cas échéant.

4. Signalement des incidents de sécurité de l'information

Il est de la responsabilité des utilisateurs de signaler dans les plus brefs délais au centre de services informatiques tout événement ou toute situation irrégulière qui pourrait constituer un incident de sécurité de l'information.

Les utilisateurs doivent signaler, en toute bonne foi et sans crainte de représailles, les comportements qui semblent contraires à la présente directive. Pour effectuer un signalement de façon confidentielle et anonyme, se référer au Code de conduite professionnelle de la Société.

5. Surveillance et enquêtes sur les activités

Toute utilisation de l'information et des technologies de l'information de l'entreprise, y compris à des fins personnelles, peut faire l'objet d'une surveillance par la Société dans les limites prescrites par loi.

La Société se réserve le droit d'enquêter sur les activités d'un utilisateur en lien avec les technologies de l'information si celles-ci peuvent contrevenir à la présente directive. Pour les employés de la Société, leur gestionnaire peut demander l'ouverture d'une enquête auprès du Service des ressources humaines et il doit appuyer sa demande par une justification.

6. Sanctions applicables

Toute violation de la présente directive pourrait faire l'objet de sanctions pouvant aller jusqu'au congédiement, à la terminaison de contrat, voire des poursuites civiles et criminelles. Toute sanction imposée sera proportionnelle à la gravité des actes posés ou des conséquences qu'ils engendrent.